

PENETRATION TEST REPORT

Acme Retail Group — External & Internal Network Penetration Test

Prepared for:	Acme Retail Group, Inc. (fictional entity — sample report)
Engagement dates:	June 2 — June 20, 2026
Report reference:	ARG-PT-2026-0142
Report date:	June 27, 2026
Classification:	CONFIDENTIAL — PREPARED FOR INTENDED RECIPIENT ONLY
Prepared by:	Northgate Offensive Security — Sample Report Template

This document is a fictional, illustrative sample penetration test report created for training, template, and educational purposes. The organization, systems, personnel, IP addresses, and findings described are not real. No content in this document targets an actual system.

1. Executive Summary

Northgate Offensive Security ('Northgate') was engaged by Acme Retail Group ('Acme' or 'the client') to perform a combined external and internal network penetration test of in-scope corporate IT environments. The objective was to identify exploitable weaknesses in externally facing infrastructure and, following an assumed-breach internal phase, to evaluate how far an attacker who obtained a foothold could progress toward compromising the Windows Active Directory domain and sensitive business data.

Testing was performed using a realistic, low-and-slow attack chain modeled on tactics, techniques, and procedures (TTPs) observed in commodity ransomware intrusions and financially motivated threat actor activity, mapped to the MITRE ATT&CK; framework. The assessment team achieved full compromise of the Active Directory domain within the internal phase, beginning from a single simulated phishing foothold and pivoting through credential exposure, misconfigured delegation, and lateral movement to Domain Administrator access.

Key Findings at a Glance

Severity	Count	Representative Issue
Critical	2	Domain compromise via Kerberoasting + unconstrained delegation abuse
High	3	Password spraying success; SMB relay to code execution; stale VPN account
Medium	4	Missing patch (public CVE), weak segmentation, verbose banners, LLMNR/NBT-NS
Low	3	Informational disclosure, missing security headers, verbose error pages
Informational	2	Password policy observations, logging/alerting gaps

Northgate recommends Acme prioritize remediation of the two Critical findings within 15 days, as they provide a direct path to full domain compromise, followed by High severity items within 30 days. Detailed remediation guidance is provided with each finding in Section 4.

2. Scope & Methodology

2.1 Scope

- External: 4 public IP ranges / 22 live hosts, including VPN gateway, mail gateway, and customer-facing web application (shop.acmeretail-sample.com)
- Internal: Assumed-breach engagement from a standard-user VLAN with no prior credentials, simulating a successful phishing compromise
- Active Directory forest: acmeretail.corp (2 domains, ~1,400 user objects, ~85 servers in scope)
- Explicitly out of scope: physical security testing, third-party SaaS platforms, denial-of-service testing, and the production payment processing enclave (PCI segment)

2.2 Methodology

Testing followed a phased methodology aligned to industry frameworks (PTES, OWASP Testing Guide, and NIST SP 800-115) with all technique selection cross-referenced to MITRE ATT&CK; for Enterprise. Phases are summarized below; the full technique-level mapping is provided separately to the client point of contact as a companion ATT&CK; Navigator layer.

Phase	Activities
Reconnaissance	OSINT collection, DNS/subdomain enumeration, employee & technology footprinting
External Assessment	Service enumeration, vulnerability validation, web application testing, password spraying against externally exposed services
Initial Access Simulation	Simulated spear-phishing payload delivery (test harness only, no real users targeted) to establish an internal foothold
Internal Assessment	Local network enumeration, credential harvesting, lateral movement, privilege escalation toward Domain Admin
Post-Exploitation / Impact	Access to representative file shares and databases to demonstrate business impact; no data was exfiltrated or altered
Reporting	Findings consolidation, CVSS scoring, ATT&CK mapping, executive and technical reporting, remediation retest offered

2.3 Risk Rating Definitions

Rating	CVSS v3.1 Range	Definition
Critical	9.0 – 10.0	Immediate, high-confidence path to full system/domain compromise
High	7.0 – 8.9	Significant compromise of confidentiality, integrity, or availability
Medium	4.0 – 6.9	Meaningful risk, typically requiring chaining with another issue
Low	0.1 – 3.9	Limited direct impact; hardening opportunity
Informational	N/A	Observation with no direct exploitability but relevant to risk posture

3. Findings Summary

ID	Finding	Severity	CVSS	ATT&CK Technique(s)
F-01	Domain Compromise via Kerberoasting of Service Accounts	Critical	9.0	T1558.003
F-02	Unconstrained Kerberos Delegation Enabling Domain Admin Escalation	Critical	9.3	T1558, T1550, T1078.002
F-03	Successful Password Spraying Against External VPN Portal	High	8.1	T1110.003, T1078
F-04	SMB Relay Leading to Remote Code Execution	High	8.6	T1557.001, T1210
F-05	Stale VPN Account for Departed Contractor	High	7.5	T1078.002, T1133
F-06	Unpatched Public-Facing Vulnerability (CVE-Class RCE)	Medium	6.8	T1190
F-07	Flat Internal Network Segmentation	Medium	5.9	T1021.002, T1049
F-08	LLMNR/NBT-NS Enabled Across Workstation Fleet	Medium	5.4	T1557.001
F-09	Verbose Server Banners & Technology Disclosure	Low	3.1	T1592
F-10	Missing Security Headers on Customer Web Application	Low	3.7	T1189
F-11	Verbose Application Error Pages	Low	3.5	T1592.002
F-12	Password Policy Below Current Best Practice	Informational	N/A	T1110
F-13	Insufficient Authentication Logging & Alerting	Informational	N/A	T1562.002

4. Detailed Findings

F-01 — Domain Compromise via Kerberoasting of Service Accounts

Severity: Critical**CVSS v3.1:** 9.0**ATT&CK:** T1558.003**Affected Assets**

acmeretail.corp domain controllers; svc-sql, svc-backup service accounts

Description

Several Active Directory service accounts were configured with Service Principal Names (SPNs) and used weak, non-rotated passwords. Any authenticated domain user could request Kerberos service tickets for these accounts and attempt offline password recovery against the ticket material, a technique commonly referred to as Kerberoasting.

Attack Narrative

After obtaining low-privileged domain credentials via the simulated phishing foothold, the assessment team enumerated SPNs across the domain and requested service tickets for accounts of interest. Offline analysis of the ticket material recovered the plaintext password for the svc-sql account, which was found to hold local administrator rights on 14 servers, including a backup management host with broader delegated permissions.

Business Impact

Recovery of the svc-sql credential materially shortened the path to lateral movement and, combined with Finding F-02, contributed directly to full domain compromise.

Remediation

- Enforce long, randomly generated passwords (25+ characters) or Group Managed Service Accounts (gMSA) for all SPN-associated accounts
- Rotate service account credentials on a regular schedule and after any suspected exposure
- Restrict service accounts to least-privilege access rather than broad administrative rights
- Deploy detection for abnormal volume of TGS-REQ requests (T1558.003) via SIEM/EDR

F-02 — Unconstrained Kerberos Delegation Enabling Domain Admin Escalation

Severity: Critical**CVSS v3.1:** 9.3**ATT&CK:** T1558, T1550, T1078.002**Affected Assets**

APP-BACKUP01 (member server, unconstrained delegation enabled)

Description

The APP-BACKUP01 server was configured for unconstrained Kerberos delegation, a legacy setting that causes the Ticket Granting Ticket (TGT) of any user authenticating to that host to be cached in memory on the server itself.

Attack Narrative

Using the local administrator access obtained via the svc-sql credential (F-01), the team monitored authentication activity on APP-BACKUP01 and, following an administrative logon by a Domain Admin-equivalent account for routine

maintenance, extracted the cached ticket material from memory. This ticket was reused to impersonate the Domain Admin account and gain full control of the acmeretail.corp domain, completing the attack chain within roughly six hours of initial foothold.

Business Impact

Full compromise of the Active Directory forest, equivalent to complete loss of confidentiality, integrity, and availability across all domain-joined systems and data.

Remediation

- Disable unconstrained delegation on all servers; migrate to constrained delegation or resource-based constrained delegation where delegation is required
- Add all privileged accounts to the 'Protected Users' security group and mark them as 'sensitive and cannot be delegated'
- Implement a tiered administration model so Tier 0 credentials never authenticate to lower-tier hosts
- Monitor for ticket-extraction and pass-the-ticket indicators via EDR (T1550.003)

F-03 — Successful Password Spraying Against External VPN Portal

Severity: High

CVSS v3.1: 8.1

ATT&CK: T1110.003, T1078

Affected Assets

vpn.acmeretail-sample.com (SSL VPN portal)

Description

The externally facing VPN portal did not enforce account lockout or meaningful rate-limiting, allowing low-and-slow password spraying without triggering a lockout threshold.

Attack Narrative

Using a list of employee names derived from public sources during the reconnaissance phase, the team performed a password spray against the VPN portal using a small set of common seasonal passwords at a rate of one attempt per account per 30 minutes. Two valid credential pairs were identified, one of which had no multi-factor authentication enrolled, granting the team a valid internal network foothold independent of the phishing scenario.

Business Impact

Provided an alternate initial access path into the internal network, bypassing endpoint controls entirely.

Remediation

- Enforce MFA for all remote access without exception
- Implement account lockout and/or adaptive throttling on authentication endpoints
- Deploy alerting for distributed authentication failures across many accounts from a single source
- Enforce a company-wide password policy prohibiting seasonal/common password patterns

F-04 — SMB Relay Leading to Remote Code Execution

Severity: High**CVSS v3.1:** 8.6**ATT&CK:** T1557.001, T1210**Affected Assets**

Internal workstation VLAN (10.20.30.0/24)

Description

SMB signing was not enforced on a subset of workstations, and LLMNR/NBT-NS name resolution fallback was enabled, allowing NTLM authentication requests to be relayed to targets that accepted unsigned SMB sessions.

Attack Narrative

The team passively captured broadcast name-resolution requests and relayed a captured authentication attempt to a workstation with SMB signing disabled, resulting in an authenticated session with local administrator rights sufficient to demonstrate code execution in a controlled, non-disruptive manner.

Business Impact

Demonstrated a low-noise path to lateral movement usable by an attacker with only network access and no prior credentials.

Remediation

- Enforce SMB signing across all workstations and servers via Group Policy
- Disable LLMNR and NetBIOS Name Service where not required
- Segment workstation VLANs from server VLANs to limit relay targets
- Enable EDR detection for anomalous SMB authentication relay patterns

F-05 — Stale VPN Account for Departed Contractor

Severity: High**CVSS v3.1:** 7.5**ATT&CK:** T1078.002, T1133**Affected Assets**

Identity & Access Management process; VPN directory

Description

A VPN account belonging to a contractor whose engagement ended approximately eight months prior was still active and had not been disabled as part of an offboarding process.

Attack Narrative

The account was identified during external enumeration of the corporate directory and, when combined with the credential found in F-03's spraying exercise, was confirmed active and capable of establishing a remote session.

Business Impact

Represents an unmonitored, unmanaged entry point that would not be captured by standard employee offboarding controls.

Remediation

- Implement automated deprovisioning tied to HR/contractor management systems
- Perform periodic (at minimum quarterly) access reviews of all remote access accounts

- Apply time-bound access expiration for contractor and vendor accounts by default

F-06 — Unpatched Public-Facing Vulnerability (CVE-Class RCE)

Severity: Medium**CVSS v3.1:** 6.8**ATT&CK:** T1190

Affected Assets

legacy-portal.acmeretail-sample.com

Description

A legacy web application component was running a version with a publicly documented remote code execution vulnerability for which a vendor patch had been available for over 90 days.

Attack Narrative

Version fingerprinting during external enumeration identified the outdated component. In keeping with the agreed rules of engagement, the team validated the presence of the vulnerability through version and configuration analysis rather than executing a working exploit against production infrastructure, and reported it for prioritized patching.

Business Impact

If exploited, could provide an attacker with code execution on the hosting server without requiring any prior access or credentials.

Remediation

- Apply the vendor security patch or upgrade to a supported version immediately
- Establish a patch SLA for internet-facing systems (recommended: Critical/High within 14 days)
- Deploy a WAF rule as a compensating control until patching is complete

F-07 — Flat Internal Network Segmentation

Severity: Medium**CVSS v3.1:** 5.9**ATT&CK:** T1021.002, T1049

Affected Assets

Corporate LAN (multiple VLANs, unrestricted east-west traffic)

Description

Internal network segmentation did not restrict east-west traffic between user workstation VLANs and internal server VLANs hosting sensitive line-of-business applications.

Attack Narrative

From the workstation foothold, the team was able to reach and enumerate server-tier hosts, including finance and HR application servers, without any firewall or ACL restriction.

Business Impact

Absence of segmentation meant a single compromised workstation provided a direct path to business-critical systems, amplifying the impact of any endpoint compromise.

Remediation

- Implement network segmentation between user, server, and management tiers

- Apply host-based firewall rules restricting unnecessary workstation-to-workstation (SMB/RDP) traffic
- Adopt a zero-trust network access model for internal application access

F-08 — LLMNR/NBT-NS Enabled Across Workstation Fleet

Severity: Medium**CVSS v3.1:** 5.4**ATT&CK:** T1557.001

Affected Assets

Workstation VLANs (fleet-wide GPO)

Description

Legacy name resolution protocols (LLMNR, NBT-NS) remained enabled fleet-wide, enabling the poisoning and relay activity described in Finding F-04.

Attack Narrative

Broadcast name-resolution requests were observed continuously throughout the internal testing window, confirming the protocols were active and unmitigated across the majority of the workstation fleet.

Business Impact

Serves as a root-cause enabler for the SMB relay attack path described in F-04.

Remediation

- Disable LLMNR via Group Policy (Turn Off Multicast Name Resolution)
- Disable NetBIOS over TCP/IP on network adapters fleet-wide
- Ensure internal DNS is authoritative and reliable so fallback protocols are unnecessary

F-09 — Verbose Server Banners & Technology Disclosure

Severity: Low**CVSS v3.1:** 3.1**ATT&CK:** T1592

Affected Assets

Multiple external hosts

Description

Several externally facing services returned verbose banners disclosing exact software versions, aiding attacker reconnaissance and vulnerability targeting.

Attack Narrative

Identified passively during the reconnaissance and service enumeration phase.

Business Impact

Lowers the effort required for an attacker to identify viable vulnerabilities to target.

Remediation

- Suppress or generalize version banners on public-facing services
- Review default error pages and server headers for unnecessary disclosure

F-10 — Missing Security Headers on Customer Web Application

Severity: Low**CVSS v3.1:** 3.7**ATT&CK:** T1189**Affected Assets**

shop.acmeretail-sample.com

Description

The customer-facing web application did not set recommended security headers such as Content-Security-Policy, Strict-Transport-Security, and X-Frame-Options.

Attack Narrative

Identified via manual and automated review of HTTP response headers.

Business Impact

Increases exposure to client-side attacks such as clickjacking and mixed-content issues.

Remediation

- Implement a strict Content-Security-Policy tailored to the application
- Enable HSTS with an appropriate max-age and includeSubDomains
- Set X-Frame-Options / frame-ancestors to prevent clickjacking

F-11 — Verbose Application Error Pages

Severity: Low**CVSS v3.1:** 3.5**ATT&CK:** T1592.002**Affected Assets**

legacy-portal.acmeretail-sample.com

Description

Triggering application errors returned stack traces including internal file paths and framework version information.

Attack Narrative

Observed while performing standard input validation testing against the web application.

Business Impact

Aids attacker fingerprinting and may reveal internal architecture details.

Remediation

- Disable verbose/debug error output in production environments
- Implement generic, user-friendly error pages with server-side logging of full detail

F-12 — Password Policy Below Current Best Practice

Severity: Informational**CVSS v3.1:** N/A**ATT&CK:** T1110**Affected Assets**

acmeretail.corp domain-wide Group Policy

Description

The domain password policy required a minimum of 8 characters with 90-day rotation, which falls short of current NIST SP 800-63B guidance favoring length over forced rotation.

Attack Narrative

Reviewed via Group Policy analysis during the internal assessment phase.

Business Impact

Contributes to weak/reused password selection, compounding findings F-01 and F-03.

Remediation

- Adopt a minimum 14-character passphrase policy
- Remove mandatory periodic rotation in favor of breach-triggered resets
- Implement a breached-password check (e.g., against known-compromised password lists) at set time

F-13 — Insufficient Authentication Logging & Alerting

Severity: Informational**CVSS v3.1:** N/A**ATT&CK:** T1562.002**Affected Assets**

SIEM / logging pipeline

Description

Authentication failure events from the VPN portal and domain controllers were logged but not forwarded to, or alerted on, within the client's SIEM during the engagement window.

Attack Narrative

The password spraying activity in F-03 and Kerberoasting activity in F-01 were not flagged by any detection or alerting mechanism throughout the two-week engagement.

Business Impact

Delays detection and response to real-world attacks using similar techniques.

Remediation

- Forward authentication logs from all identity providers to the SIEM
- Build detection content for password spraying, Kerberoasting, and ticket-relay patterns
- Establish an alert triage and response SLA for high-confidence identity alerts

5. Conclusion

The assessment demonstrated that a single successful phishing interaction, combined with common Active Directory misconfigurations, was sufficient to achieve full domain compromise. None of the individual techniques used were novel; the overall risk stems from the absence of layered controls that would have interrupted the chain at an earlier stage — such as tiered administration, credential hygiene, and network segmentation. Northgate recommends Acme adopt an assumed-breach posture in future architecture decisions and re-engage for a validation retest once remediations in Section 4 are implemented.

6. Appendix A — Tools Used

- Nmap, Masscan — network and service discovery
- Burp Suite Professional — web application testing
- BloodHound / SharpHound — Active Directory relationship mapping
- Impacket toolkit — protocol interaction and authentication testing
- Responder — LLMNR/NBT-NS poisoning detection
- Mimikatz (isolated lab use only, for credential material validation) — used strictly within the assumed-breach test host under client-approved rules of engagement
- Custom Python/PowerShell tooling for enumeration and reporting

7. Appendix B — Disclaimer

This report is a fictional sample created for illustrative and educational purposes only. All company names, individuals, IP addresses, hostnames, and findings are invented and any resemblance to real organizations or systems is coincidental. This document does not contain functional exploit code, malware, or step-by-step attack instructions, and should not be used as such.